

ソフトウェアサプライチェーンセキュリティ分析のための GSN 自動生成手法と適用事例

太田雄貴

1 まえがき

ソフトウェアサプライチェーンセキュリティとは、ソフトウェアの開発から配布、そして利用に至るまでの全ての段階において、その安全性を確保するための取り組みを指す。近年、情報セキュリティ分野ではサプライチェーンセキュリティに焦点が当てられている。

我々は、ソフトウェアサプライチェーンのセキュリティを効果的に評価するために、GSN(Goal Structuring Notation) に注目した。本研究では、後述のサプライチェーンセキュリティモデルである AStRA モデルから GSN を自動生成し、システムのサプライチェーンの抱えるセキュリティリスクを可視化して対策を容易にすることを目指す。

2 先行研究

ソフトウェアサプライチェーンの脅威分析や保証に関する先行研究として、本節では SLSA[1] を挙げる。

SLSA はセキュリティ成熟度を 4 段階で評価し、レベルが高いほど堅牢性が増す。SLSA はレベル分類にとどまるが、本研究は各コンポーネントの対策や脆弱性要因を同時に分析可能な点で異なる。

3 AStRA モデル [2] について

AStRA モデルは、サプライチェーンセキュリティに特化したモデルである。

システムを非巡回有向グラフで表し、コンポーネントを Principal (主体)・Artifact (成果物)・Step (工程)・Resources (資源)・Topology (全体構造) の 5 つに分類する。これに基づき、依存関係や各要素のセキュリティ要件の充足性を分析する。

4 GSN[3] の説明

GSN は、システムの安全性を論理的・構造的に示す記法である。本研究では以下の 4 要素を用いる。

Goal は目標や主張、Strategy は論証方策、Evidence は根拠である。Undeveloped は証拠の不在を表す。

本研究では、これら 4 要素による GSN の自動生成を行う。

5 提案手法

本研究の提案手法のイメージを図 1 に示す。



(図 1 挿入箇所)

図 1 本研究のイメージ図

まず、AStRA モデルのコンポーネントを Node、依存関係を Edge として入力する。各 Node にはセキュリティ証明用の Evidence を添付できる。

次に、GSN 構築のため Node を分類し、対応する Goal および SubGoal を生成する。この際、添付された Evidence があれば Goal の根拠とし、なければ Undeveloped (要件未達) とする。

生成時には Undeveloped な Goal を収集・リスト化する。これにより、システムの安全性確保に必要な残存要件を確認できる。

また、AStRA モデルの 5 つ目の要素である Topology について今回は考慮しないものとした。

6 評価

具体的な事例として SolarWinds 事件を取り上げ、AStRA モデルから GSN を生成して対策を考察する。詳細については以下のリンクに詳細を示している^{*1*2}。

SolarWinds 事件 (2020 年) は、攻撃者が CI/CD 管理者アカウントを乗っ取り、ビルドシステムへマルウェア

アを混入させた大規模なサプライチェーン攻撃である。マルウェアは製品アップデートを通じて顧客端末へ拡散し、情報窃取に悪用された。本研究では、この事件発生前後における対策の GSN を生成し、比較を行った。

比較の結果、事件前に対策が欠如していた一方、事件後 [4] は多要素認証の導入や最小権限の原則が適用された。また、ビルドシステムの使用ごとの破棄・再構築、操作記録の徹底、悪用時の証明書破棄といった対策が講じられた。

SolarWinds 事件前のシステム (Node 数 22、Edge 数 27) を対象に GSN を生成した結果、Subgoal 総数は 44 に達した。図 2 にその一部として、攻撃を受けた箇所を示す。



図 2 SolarWinds 事件時の GSN 図の一部

侵入経路となった CI/CD controller (Principal) には安全性を示す Evidence が付与されておらず、安全性が担保されていない状態であった。Evidence が欠如し要件を満たさない項目については、不足する Evidence のリストと必要なセキュリティ対策が提示される。

事件後に対策を講じたシステムについても、同様に GSN を生成した。CI/CD controller および Build への対策追加により、SolarWinds 事件と同種の攻撃を検知・対処可能となった。

以上の結果、本手法は手作業では困難な規模の GSN を短時間で自動生成し、サプライチェーンの脆弱性や不足する対策の特定を可能にした。また、事件前後の比較

を通じ、同種の攻撃に対する対策の有効性も確認された。

7 まとめ

本研究では、昨今重要度を増すサプライチェーンのセキュリティについて、AStRA モデルと GSN を用いてサプライチェーンのセキュリティリスクの可視化と、不足するセキュリティの要件とそれを満たせる取り組みを示せた。

参考文献

- [1] SLISA, <https://slisa.dev/spec/v0.1/levels>
- [2] Ishgair et al. "SoK: A Defense-Oriented Evaluation of Software Supply Chain Security." arXiv:2405.14993 (2024).
- [3] GSN Community Standard version3
- [4] SolarWinds 社 ホーム ページ, <https://www.solarwinds.com/blog/setting-the-new-standard-in-secure-software-development>

*1 <https://drive.google.com/file/d/1b3aXRGjQ5kwdeJ499K3UZWBcBaNh76x/view?usp=sharing>

*2 <https://drive.google.com/file/d/11n5SFFpk03fm3jTGdrVXzCczFLkQF1PS/view?usp=sharing>